

Guia LGPD para a clínica pequena

Dado de saúde é sensível: o que guardar, onde, por quanto tempo, quem acessa, e o que nunca colar em IA pública.
Bônus do kit.

Uma clínica médica guarda o dado pessoal mais protegido que existe: o de saúde. Prontuário, exame, receita, guia de convênio, conversa de WhatsApp com "doutor, o resultado deu...". A Lei Geral de Proteção de Dados (Lei 13.709/2018) classifica dado de saúde como **dado pessoal sensível** (art. 5º, II) e dá a ele um regime próprio (art. 11). Ela vale para o consultório de um médico só do mesmo jeito que vale para o hospital. Este guia é o mínimo prático para uma clínica de 2 a 6 pessoas: saber o que guarda, onde, por quanto tempo, quem acessa, o que nunca colar em uma IA pública e o que fazer se algo vazar.

O que este guia não é. Não é parecer, não garante conformidade com a LGPD e não substitui a análise de um advogado nem as normas do CFM e do seu CRM sobre prontuário, sigilo e guarda de documentos. Ele organiza a casa para que essa análise seja rápida. Onde houver dúvida sobre base legal, prazo de guarda ou comunicação de incidente, a decisão é jurídica e é sua.

O que o kit guarda. As 20 planilhas do kit não são prontuário e não devem receber nada clínico: só nome, contato, pagador, procedimento (o nome administrativo), valor, data e situação. Este guia trata de tudo o que a clínica guarda, dentro e fora do kit.

1. Por que isso importa para uma clínica pequena

Três motivos, do mais frequente ao mais grave:

- **Paciente pergunta.** "Quem vê o meu exame?", "vocês mandam por WhatsApp?", "posso pedir uma cópia?". Responder com uma página pronta tranquiliza; responder "fica no computador da recepção" não.
- **Celular perdido, WhatsApp da recepção invadido, ex-funcionário com a senha do sistema.** É o incidente comum. Sem mapa do que existe e onde, você não sabe nem o que foi exposto.
- **Sigilo médico e LGPD andam juntos.** O Código de Ética Médica já obriga ao sigilo; a LGPD acrescenta deveres de organização, minimização, segurança e resposta a incidente, com o agravante de que dado de saúde é sensível: a régua é mais alta e a multa também. Um reforça o outro.

2. O que a clínica guarda (inventário)

Preencha a tabela abaixo uma vez e revise a cada seis meses. É o "mapa de dados" simplificado; sem ele, nada do resto funciona. A coluna "Sensível" segue a lista da LGPD (art. 5º, II: saúde, vida sexual, dado genético ou biométrico, origem racial, religião, opinião política, entre outros).

TIPO DE DADO	EXEMPLOS	DE QUEM	SENSÍVEL?	ONDE FICA (SEÇÃO 3)
Identificação e contato	nome, CPF, RG, data de nascimento, endereço, telefone, e-mail	pacientes, responsáveis	não	cadastro do sistema, Planilha 1 (nome e contato)
Convênio	operadora, número da carteirinha, guias, autorizações	pacientes	não, mas dá acesso ao histórico	sistema, pasta de lotes, Planilha 13 (guia, valor, data)

TIPO DE DADO	EXEMPLOS	DE QUEM	SENSÍVEL?	ONDE FICA (SEÇÃO 3)
Financeiro	valor pago, parcelas, forma de pagamento, nota fiscal, dados de cartão	pacientes	não, mas confidencial	Planilhas 9, 14, 16; maquininha; sistema da prefeitura
Saúde	prontuário, anamnese, exames, laudos, receitas, atestados, fotos clínicas, resultado enviado por mensagem	pacientes	sim	prontuário (papel ou eletrônico), e-mail, WhatsApp, equipamentos (ECG, MAPA, Holter)
Menores e responsáveis	dados de crianças, quem acompanha	pacientes menores	sim (menores)	prontuário e cadastro
Equipe	dados da recepcionista, médicos parceiros, contador	equipe	às vezes (saúde, atestado)	pasta administrativa, Planilhas 5 e 11
Contatos e orçamentos	nome e telefone de quem pediu orçamento e não fechou	possíveis pacientes	não	celular da recepção, Planilha 15
Dados das planilhas do kit	nome do paciente, pagador, procedimento, valor, data	pacientes (indiretamente)	não, desde que nada clínico entre	pasta de gestão

Regra prática de minimização: se o dado não é necessário para atender, agendar, cobrar ou cumprir obrigação legal, não peça. Foto do documento serve; cópia do cartão de crédito, não. Procedimento nas planilhas do kit é só o nome administrativo ("consulta", "ECG", "MAPA"); o motivo, o resultado e a conduta ficam no prontuário.

Base legal de dado de saúde. A LGPD prevê hipóteses próprias para tratar dado sensível (art. 11), entre elas a tutela da saúde por profissional de saúde e o cumprimento de obrigação legal ou regulatória; o consentimento é só uma delas e nem sempre é a adequada. Qual hipótese se aplica a cada uso (atendimento, faturamento do convênio, cobrança, marketing) é análise jurídica: anote a resposta de quem cuida do jurídico na tabela da seção 4 e não improvise.

3. Onde fica cada coisa

O problema da clínica pequena não é o servidor; é o dado espalhado. Faça a lista real, sem vergonha:

LUGAR	O QUE COSTUMA TER	RISCO PRINCIPAL	MÍNIMO A FAZER
Sistema de prontuário ou pasta de papel	prontuários, exames, receitas	acesso de quem não atende, armário aberto	login por pessoa no sistema; armário com chave; regra de quem abre o quê

LUGAR	O QUE COSTUMA TER	RISCO PRINCIPAL	MÍNIMO A FAZER
Computador da recepção	cadastro, agenda, planilhas do kit, PDFs de exames que chegaram por e-mail	roubo, defeito sem backup, tela virada para a sala de espera	senha de login, disco criptografado (BitLocker/FileVault), backup, tela bloqueada ao sair
Celular do médico e da recepção	fotos de exame, conversas com pacientes, resultados	perda, backup automático na nuvem pessoal, mensagem no grupo errado	bloqueio de tela, criptografia, apagamento remoto ativado, número da clínica separado do pessoal
WhatsApp da clínica	confirmações, comprovantes de Pix, fotos de pedido de exame, resultado que o paciente mandou	backup na nuvem pessoal, mídia guardada por anos, envio para a pessoa errada	backup na nuvem desligado ou criptografado, mídia apagada depois de salvar no prontuário, verificação em duas etapas
E-mail	laudos, anexos de anos, notas fiscais	invasão, encaminhamento errado	autenticação em dois fatores, senha única, não usar o e-mail como arquivo
Equipamentos (ECG, MAPA, Holter, ultrassom)	exames com nome do paciente na memória do aparelho ou no computador ligado a ele	aparelho vendido ou levado para manutenção com os exames dentro	apagar a memória antes de sair da clínica; exportar para o prontuário e limpar
Nuvem (Drive, OneDrive, Dropbox)	pasta de gestão, exames escaneados	link "qualquer pessoa com o link", conta pessoal do sócio	conta da clínica, compartilhamento por pessoa, revisão de links
Portais de convênio e sistema da prefeitura (nota fiscal)	dados que você enviou	vazamento deles, senha compartilhada	uma senha por pessoa quando o portal permite; saber o contato de cada um
Papel	guias, fichas, pedidos de exame, resultados impressos, anotações	balcão da recepção, lixo comum	fora da vista do público, armário com chave, fragmentadora
Ferramentas de IA	o que alguém colou lá	retenção pelo fornecedor, uso para treino	seção 6

Recomendação de estrutura mínima: **prontuário em um lugar só** (sistema ou pasta física), e o resto da clínica em uma conta de nuvem da clínica (não do sócio), com pastas fixas: **01-gestao** (as planilhas do kit), **02-convenios** (lotes, demonstrativos, recursos de glosa), **03-financeiro** (notas, extratos), **04-equipe**, **05-administrativo**. Nada clínico fora do prontuário: exame que chega pelo WhatsApp vai para o prontuário no mesmo dia e sai do celular.

4. Por quanto tempo guardar

Aqui a decisão é jurídica e regulatória. O prazo de guarda do prontuário é matéria do CFM (há resolução própria sobre guarda, digitalização e eliminação de prontuário, com prazos diferentes para papel e meio eletrônico) e pode ter regra adicional do seu CRM e da vigilância sanitária; documentos fiscais e de convênio têm prazos próprios. **O guia não fixa nenhum prazo**; ele obriga você a anotar, com a fonte, o que vale para a sua clínica. Preencha com quem cuida do jurídico e com o contador:

CONJUNTO	PRAZO DEFINIDO PARA A CLÍNICA	FONTE (RESOLUÇÃO, LEI, CONTADOR)	QUEM DEFINIU	DATA
Prontuário em papel	[] anos após o último atendimento	Resolução do CFM vigente sobre guarda de prontuário		
Prontuário eletrônico	[]	Resolução do CFM vigente; norma do sistema certificado		
Exames e laudos avulsos (fora do prontuário)	[]			
Guias, lotes e demonstrativos de convênio	[] anos	contrato com a operadora; contador		
Documentos fiscais (notas, guias de imposto)	[] anos	contador		
Cadastro e contato de quem pediu orçamento e não fechou	[] meses	decisão da clínica		
Conversas de WhatsApp com pacientes	[] (após salvar no prontuário o que for clínico)	decisão da clínica		
Dados das planilhas do kit (nome, valor, data)	[] anos (o mesmo do financeiro)	contador		
Backups	[] versões / meses	decisão da clínica		

Três regras que não dependem de prazo:

1. **Anote a data do último atendimento** de cada paciente (a Agenda, Planilha 1, já tem). Sem ela, o relógio de guarda não começa.
2. **Apagar é apagar.** Lixeira da nuvem, backup antigo, memória do aparelho de ECG e o celular da recepção precisam entrar na rotina de descarte. Papel com dado de saúde vai para a fragmentadora, nunca para o lixo comum. Prontuário só é eliminado nas condições que o CFM determina.
3. **Quando o prazo chega, alguém decide.** Uma tarefa "revisar descarte" por semestre na Rotina da semana (Planilha 3), com dono, resolve.

5. Quem acessa o quê

Clínica de 2 a 6 pessoas costuma ter todo mundo com acesso a tudo, inclusive ao prontuário. É cômodo e é o maior risco. Regra simples:

PESSOA	ACESSA	NÃO ACESSA
Médicos sócios	prontuário dos próprios pacientes e da clínica, financeiro, planilhas do kit	conta pessoal um do outro
Médico parceiro	prontuário dos pacientes que atende; a própria produção (Planilha 11)	financeiro da clínica, prontuário de outros profissionais, Caixa (09)
Recepção	agenda, cadastro, cobrança, guias de convênio, checklist do dia, Planilhas 1, 2, 4, 13, 14, 15	conteúdo do prontuário, exames, laudos; Planilhas 5, 11, 12, 18
Contador	resumo do mês, notas, extratos, retiradas, totais por origem e categoria	qualquer dado de paciente: nome, guia, procedimento por pessoa
Suporte de TI ou do sistema	o que for necessário para o serviço, com registro	prontuário sem supervisão; cópia de base de dados fora da clínica
Operadoras de convênio	o que a guia e o contrato exigem	o que o contrato não exige (o médico decide o que vai na justificativa)

Checklist de acesso:

- ☐ Cada pessoa tem o próprio login no sistema, no e-mail e na nuvem (nada de senha da recepção colada no monitor).
- ☐ Autenticação em dois fatores no e-mail, na nuvem, no WhatsApp da clínica e nos portais que permitem.
- ☐ Quando alguém sai (recepcionista, médico parceiro), o acesso é cortado no mesmo dia: sistema, e-mail, nuvem, grupos de WhatsApp, chave do armário.
- ☐ Compartilhamento na nuvem é por pessoa, nunca por "qualquer pessoa com o link".
- ☐ Um termo simples de confidencialidade assinado pela recepção e por cada médico parceiro (o seu modelo, revisado por quem cuida do jurídico), com a frase sobre IA da seção 6.
- ☐ A tela da recepção não fica visível da sala de espera; a impressora não fica com exame na bandeja.
- ☐ Revisão de acessos a cada seis meses, junto com o inventário da seção 2.

6. O que nunca colar em uma IA pública

IA pública é qualquer ferramenta em que você digita e a resposta vem de um servidor de terceiro (ChatGPT, Gemini, Copilot, Claude e outras, especialmente nas versões gratuitas ou pessoais). O que entra pode ser guardado pelo fornecedor, revisado por pessoas e, em alguns planos, usado para treinar

modelos. Sigilo médico e LGPD não param na porta da ferramenta, e dado de saúde é sensível: um vazamento aqui é o pior caso.

Nunca:

- nome, CPF, data de nascimento, endereço, telefone, e-mail ou número de carteirinha de paciente ou responsável;
- qualquer informação de saúde: motivo da consulta, sintoma, diagnóstico, exame, laudo, receita, atestado, evolução, foto clínica, resumo de prontuário, mesmo "só para resumir";
- número de guia junto com o nome, ou qualquer combinação que identifique a pessoa pelo contexto ("o único paciente de MAPA da terça");
- foto, áudio ou vídeo de documento ou de exame;
- justificativa clínica de recurso de glosa (o recurso administrativo pode ir sem nome; o clínico não vai);
- dado de equipe (salário, atestado, avaliação) com nome.

Pode, com cuidado:

- números de gestão sem identificação: horas, ocupação, faltas, valores, datas, procedimento como nome administrativo, "Paciente A", "Convênio 1" (é assim que os 40 prompts do kit funcionam);
- textos seus, administrativos, sem dado de terceiro (rotina, pauta, mensagem padrão);
- perguntas gerais de gestão, planilha e escrita.

Como anonimizar em 30 segundos: copie o bloco da planilha para um texto, troque a coluna Paciente por letras (A, B, C), apague contato e número de guia, deixe só procedimento, valor, data, pagador e situação, e leia uma vez procurando nome próprio ou número. Se o texto continua identificando alguém pelo contexto, troque o contexto também. O bloco único da Planilha 20 é o único texto do kit pronto para colar sem tratamento: ele só tem totais.

Se a clínica decidir usar IA com dados reais (transcrição de consulta, resumo de prontuário, apoio a laudo), isso exige ferramenta com contrato de tratamento de dados, retenção zero, hospedagem e sigilo definidos, o "de acordo" de quem cuida do jurídico e as regras do CFM sobre o uso de tecnologia na prática médica. Enquanto não tiver, a regra é a de cima. E escreva a regra: uma linha no termo de confidencialidade da equipe resolve ("é proibido inserir qualquer dado de paciente em ferramenta de inteligência artificial sem autorização por escrito do sócio responsável").

7. Mínimo de segurança que cabe em uma tarde

Não é tudo o que se pode fazer; é o que uma clínica pequena consegue fazer sem contratar ninguém, em ordem de retorno:

1. **Dois fatores em tudo** (e-mail, nuvem, WhatsApp da clínica, banco, sistema de prontuário, portais de convênio que permitem): 40 minutos.

2. **Gerenciador de senhas** para a equipe, com uma senha diferente por serviço e uma por pessoa: 1 hora.
3. **Criptografia de disco** ligada nos computadores e bloqueio de tela em 2 minutos, inclusive no da recepção: 20 minutos.
4. **Backup automático** do que não está no sistema de prontuário (pasta de gestão, exames escaneados, lotes de convênio) em um segundo lugar, com teste de restauração a cada trimestre; e a confirmação, por escrito, de como o sistema de prontuário faz o backup dele: 1 hora.
5. **WhatsApp da clínica** em número separado do pessoal, com verificação em duas etapas e backup na nuvem desligado (ou criptografado); mídia apagada depois de ir para o prontuário: 30 minutos.
6. **Equipamentos:** rotina de exportar e apagar a memória do ECG, MAPA e Holter; antes de qualquer manutenção externa ou venda, memória limpa: 20 minutos para escrever a rotina.
7. **Atualizações automáticas** do sistema e do navegador: 10 minutos.
8. **Um e-mail de teste de golpe** para a equipe a cada seis meses, para ninguém clicar em "seu lote foi glosado, veja o anexo" ou "atualize a senha do portal": 20 minutos.

8. Se algo vazar: o que fazer nos primeiros 3 dias

Vazamento é qualquer situação em que dado pessoal foi visto, copiado, perdido ou ficou acessível por quem não devia: celular perdido, exame enviado para o paciente errado, prontuário aberto na tela da recepção, link aberto na nuvem, invasão de conta, papel esquecido no balcão, aparelho de ECG levado com exames na memória. Com dado de saúde, presume risco relevante até prova em contrário. Não é hora de julgar; é hora de agir na ordem:

1. **Conter (hora 0).** Bloquear o aparelho ou apagar remotamente; trocar a senha e derrubar as sessões abertas; fechar o link; pedir ao destinatário errado que apague e confirme por escrito.
2. **Registrar (hora 1).** Em um documento com data e hora: o que aconteceu, quando foi descoberto, quais dados e de quantas pessoas, se havia dado de saúde, quem teve acesso, o que foi feito. Esse registro é obrigatório na prática e vai ser pedido depois.
3. **Avaliar (dia 1).** Com quem cuida do jurídico da clínica: há risco ou dano relevante para as pessoas afetadas (dado de saúde, de menor, financeiro, volume grande)? Essa avaliação decide o passo 4.
4. **Comunicar (até 3 dias úteis).** A LGPD prevê comunicação à ANPD e aos titulares quando o incidente pode acarretar risco ou dano relevante; o regulamento da ANPD (Resolução CD/ANPD nº 15/2024) fixa o prazo de 3 dias úteis contados do conhecimento do incidente para a comunicação à autoridade, com o formulário próprio dela. Confirme a regra vigente na data do incidente: quem decide se comunica, o que e quando é a análise jurídica, não este guia. Paciente afetado costuma preferir saber por você antes de saber por outro caminho, e com dado de saúde isso pesa mais.
5. **Corrigir (semana 1).** O que permitiu o incidente (senha fraca, link aberto, celular sem bloqueio, tela virada) entra na lista da seção 7 e é resolvido antes de qualquer outra coisa.

6. **Aprender (mês 1).** Uma linha no registro de incidentes da clínica (basta uma planilha com data, o que foi, quantas pessoas, havia dado de saúde?, o que mudou) e o assunto entra na revisão semestral.

Tenha à mão, antes de precisar: telefone da operadora do celular, contato do suporte do sistema de prontuário, da nuvem e do e-mail, contato do contador, e o nome de quem cuida do jurídico da clínica.

9. Modelo simples de aviso de privacidade para a clínica

Use como ponto de partida. Troque os colchetes, apague o que não se aplica e peça a revisão de quem cuida do jurídico da clínica antes de publicar. Publique em uma página própria do site (/privacidade), deixe uma cópia impressa na recepção e aponte para ela no formulário de cadastro e na primeira mensagem de confirmação. Se o site tiver qualquer texto de divulgação, ele segue as regras do CFM/CRM; o aviso de privacidade é só o aviso.

Aviso de privacidade · [Nome da clínica]
Última atualização: [data]

Quem somos. [Nome da clínica], CNPJ [], com responsável técnico [nome, CRM/UF nº], endereço [], é a responsável pelo tratamento dos dados pessoais descritos aqui. Contato para assuntos de privacidade: [e-mail].

Quais dados tratamos. (a) Dados de cadastro e contato (nome, documento, data de nascimento, telefone, e-mail, endereço, convênio e carteirinha). (b) Dados necessários ao atendimento, que incluem dados de saúde: histórico, exames, laudos, prescrições e o prontuário, mantidos pelo médico responsável. (c) Dados de pagamento (valores, forma de pagamento, notas fiscais). (d) Dados de navegação coletados por cookies no site, se você consentir.

Para que usamos. Agendar e prestar o atendimento; manter o prontuário conforme as normas do Conselho Federal de Medicina; faturar convênios e emitir cobranças e documentos fiscais; cumprir obrigações legais e regulatórias; e, se você autorizar, enviar lembretes e comunicações administrativas da clínica.

Base legal. Tratamos dados de saúde com fundamento na tutela da saúde, em procedimento realizado por profissionais de saúde, e no cumprimento de obrigação legal e regulatória; os demais dados, na execução do contrato de prestação de serviços, no cumprimento de obrigação legal, no exercício regular de direitos e, quando aplicável, no seu consentimento, que pode ser retirado a qualquer momento.

Com quem compartilhamos. Apenas com quem precisa para a prestação do serviço: operadoras de planos de saúde (para autorização e faturamento, nos limites do contrato), laboratórios e serviços de apoio diagnóstico que você utilizar, contador da clínica (somente dados financeiros, sem dados de saúde), provedores de tecnologia (sistema de prontuário, armazenamento, e-mail, meio de pagamento) e autoridades quando a lei exigir. Não vendemos dados. Não inserimos dados de pacientes em ferramentas de inteligência artificial sem contrato que garanta sigilo.

Por quanto tempo. O prontuário é guardado pelo prazo definido pelo Conselho Federal de Medicina; os demais dados, pelo período necessário à prestação do serviço e ao cumprimento de prazos legais; depois, são eliminados ou anonimizados. Dados de quem pediu orçamento e não contratou são apagados em até [] meses.

Seus direitos. Confirmação, acesso, correção, anonimização, portabilidade, informação sobre compartilhamento, revogação do consentimento e eliminação, nos limites da lei, do sigilo

profissional e das normas de guarda de prontuário. Você pode pedir cópia do seu prontuário. Para exercer seus direitos, escreva para [e-mail]. Respondemos em até [15] dias.

Segurança. Adotamos medidas técnicas e administrativas para proteger seus dados, como controle de acesso por pessoa, autenticação em dois fatores, criptografia e cópias de segurança.

Cookies. [Este site usa apenas cookies necessários ao funcionamento. / Este site usa cookies de estatística mediante o seu consentimento; você pode gerenciá-los em [link].]

Alterações. Este aviso pode ser atualizado; a data acima indica a versão vigente.

10. Checklist de dez minutos (a cada seis meses)

- ☐ Inventário da seção 2 revisado; nada clínico fora do prontuário; nada novo espalhado.
- ☐ Nenhum link "qualquer pessoa com o link" aberto na nuvem.
- ☐ Todo mundo com dois fatores ativos; ninguém que saiu ainda com acesso.
- ☐ Backup testado: restaurei um arquivo da pasta de gestão; o sistema de prontuário confirmou o backup dele.
- ☐ WhatsApp da clínica sem exame ou documento pendente de mover para o prontuário.
- ☐ Memória dos equipamentos exportada e limpa; nenhum aparelho saiu para manutenção com exame dentro.
- ☐ Prazos da seção 4 preenchidos com fonte; descartes do semestre feitos e anotados.
- ☐ Nenhum prompt de IA usado no semestre continha nome, contato ou dado de saúde (perguntar à equipe).
- ☐ Aviso de privacidade com data de atualização recente, contato válido e responsável técnico correto.
- ☐ Registro de incidentes lido; ações do último incidente concluídas.
- ☐ Data da próxima revisão marcada na Rotina da semana (Planilha 3) como tarefa interna.

Este guia é um ponto de partida de gestão. Não promete conformidade: conformidade é resultado de análise jurídica, de rotina e de revisão. Quem cuida do jurídico da clínica deve validar cada decisão marcada como "definida pela clínica", e as normas do CFM e do seu CRM prevalecem sobre qualquer sugestão daqui.

Suporte: suporte@seusociogestor.com.br · Reembolso em até 7 dias.